ELMS-006 — Default Administrator Credentials & Hardcoded Empty-Password DB Root

Attribute	Detail
Finding ID	ELMS-006
Severity	High
CVSS 4.0	8.6 — CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N
OWASP 2021	A05 — Security Misconfiguration (also A07)
CWE	CWE-1392, CWE-798, CWE-258, CWE-1188
Affected component	http://localhost/elms/admin/; includes/config.php, admin/includes/config.php; readme.txt
Parameters	username / password (admin login); DB connection credentials
Auth context	None — the credentials are the access
Status	Confirmed

Description & Root Cause

ELMS ships with a known default administrator login (`admin` / `Test@12345`) — documented in the web-accessible `readme.txt` and seeded in the `admin` table — and connects to MariaDB as `root` with an **empty password**, hardcoded in `includes/config.php` (`DB_USER='root'`, `DB_PASS=''`). There is no forced credential change on first run. Deployed as-is (as this instance is), an attacker gains the admin panel and database-superuser access with no real attack.

Business Impact

Immediate administrative compromise (manage all employees, departments and leave) and, via the empty-password `root` DB account, full database control. This is the terminal edge of Chain A.

Proof of Concept — Step by Step

Step 1 — Read the published credentials. `GET /elms/readme.txt` returns the admin username and password in plaintext.

Step 2 — Authenticate to the admin panel. Submit `admin` / `Test@12345` at `/elms/admin/`. The application authenticates and redirects to the admin dashboard.

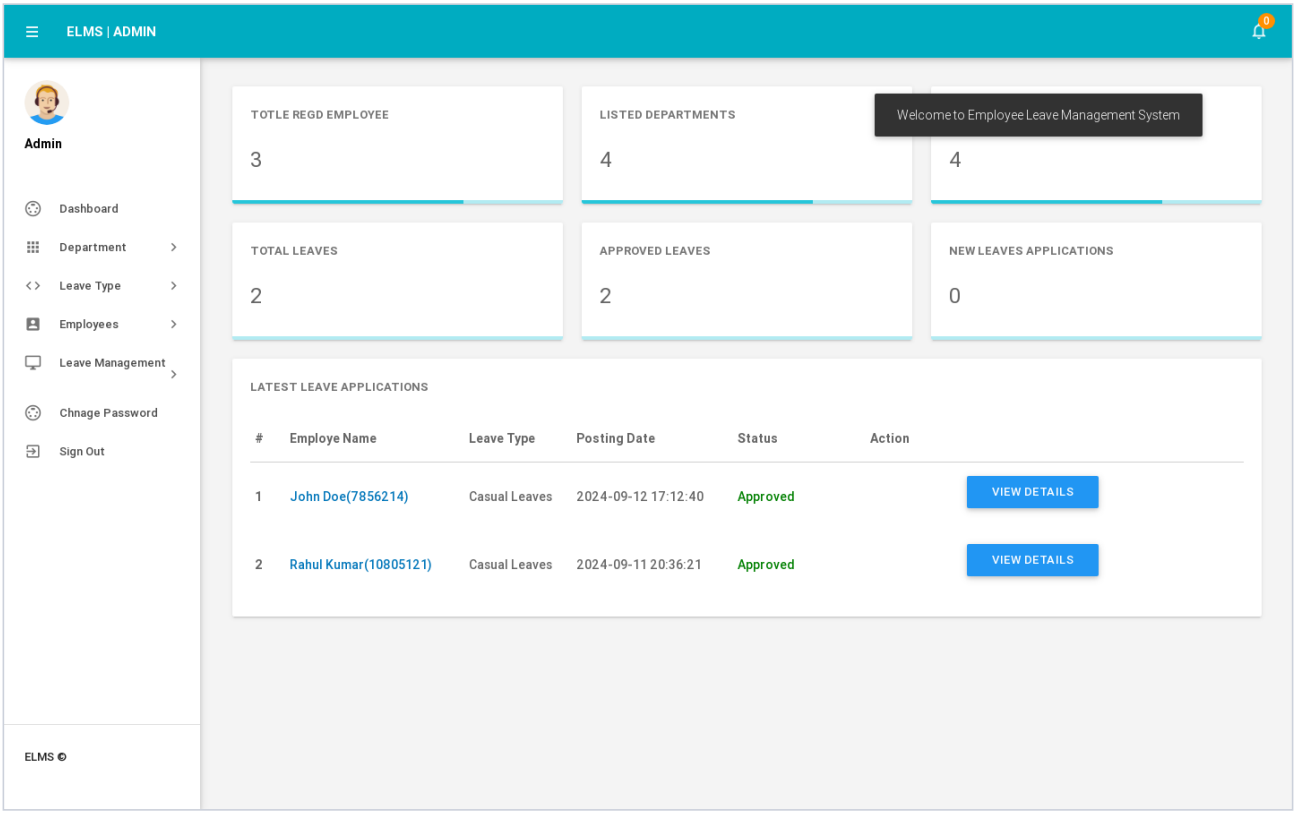


Figure 1 — Administrative access achieved with the default credentials admin / Test@12345: the authenticated admin dashboard shows registered-employee counts, department/leave totals, and every employee's leave applications (John Doe, Rahul Kumar). Red-box focus: the "ELMS | ADMIN" banner and the populated management widgets, confirming full admin control.

Step 3 — Confirm the DB superuser exposure. `includes/config.php` defines the application's DB connection as `root` with an empty password — unrestricted database rights baked into source.

Exploit payload:

```
GET /elms/readme.txt HTTP/1.1          # publishes: Username: admin  Password: Test@12345
Host: localhost

POST /elms/admin/index.php HTTP/1.1
Content-Type: application/x-www-form-urlencoded

username=admin&password=Test@12345&signin=
```

HTTP Evidence

`readme.txt` (200) contains `Admin Credential Username: admin Password: Test@12345`. The admin login responds with the dashboard redirect (successful auth). Config: `define('DB_USER','root'); define('DB_PASS','');`.

Remediation

Force an admin password change on first login; never ship real credentials. Remove `readme.txt` from the web root. Create a dedicated least-privileged DB user (not `root`, never empty), store secrets outside the web root / in environment configuration, and rotate the admin password and DB credentials now.

```
// config.php — load from environment, least privilege, never empty
$dbh = new PDO(
  'mysql:host='.getenv('DB_HOST').';dbname='.getenv('DB_NAME'),
  getenv('DB_USER'),     // e.g. 'elms_app' with only CRUD on elmsdb
  getenv('DB_PASS'),     // strong secret, injected at deploy time
  [PDO::ATTR_ERRMODE => PDO::ERRMODE_EXCEPTION]
);
```

```
// First-run gate: require the admin to set a new password before any other action.
```

Re-test Procedure

Confirm `readme.txt` is gone, the default admin password no longer authenticates, and the application's DB user is a non-root, least-privileged account with a non-empty password.

Exploitation Feasibility

Trivial — the credentials are published and functional.

Existing CVE Verification

No product CVE; this is a deployment/configuration issue. Status: **No matching CVE identified / not applicable**.

References

- OWASP WSTG-ATHN-02 (Default Credentials); A05:2021; CWE-1392/798/258.

Conclusion

Confirmed default admin credentials (published in an accessible readme) and a hardcoded empty-password DB root. High severity as deployed. Change/rotate credentials, remove the readme, and use a least-privileged DB account.